Documentación de cumplimiento normativo

ColaboraFP · Centro de Formación Profesional José Ramón Otero · Versión de 15 de octubre de 2026

1. Estado de cumplimiento

Ámbito	Situación	Cómo se cumple
Protección de datos (RGPD / LOPDGDD)	**Cumple, con 3 pasos administrativos (apartado 2)**	Política de privacidad (art. 13 RGPD); información básica en el punto de recogida; plazos de borrado automáticos (cierre a las 12 h, borrado a los 60 días); derecho de supresión desde el panel; datos en la UE; tipografías autoalojadas sin transferencias a Google Fonts; sin cookies ni analítica. Pendiente: aceptar los contratos de encargo de Google y Netlify, inscribir el tratamiento en el RAT y activar el TTL.
Servicios de la sociedad de la información (LSSI)	**Cumple al completar los datos del titular**	Aviso legal (art. 10), condiciones de uso, punto de contacto en el pie de todas las páginas y canal de notificación de contenidos (art. 16): botón «Notificar contenido» en cada recurso, con aviso en tiempo real al profesor y correo al centro. Falta rellenar NIF, razón social, dirección, correo y DPD (variables `VITE_CENTRO_*`).
Seguridad	**Cumple**	Contenido aislado por sala (imposible listar entre salas), PIN alfanumérico criptográfico no enumerable (≈887 millones de combinaciones) que solo se resuelve con la sala abierta, cierre automático, registro limitado al correo verificado del centro, reglas validadas en el servidor y cabeceras CSP, HSTS y Permissions-Policy.
Propiedad intelectual	**Cumple**	Condiciones de uso con declaración de autoría, cita de fuentes (art. 32 TRLPI) y licencia limitada a la sala y a su plazo; aceptación expresa al registrarse y al compartir; moderación previa de las aportaciones del alumnado.
Accesibilidad (RD 1112/2018)	**Cumple (WCAG 2.1 AA en la interfaz)**	0 incumplimientos en axe-core en 40 pantallas (claro y oscuro, escritorio y móvil), enlace de salto, foco controlado en diálogos, movimiento reducido y declaración de accesibilidad publicada. El contenido que suben los usuarios queda fuera de esa garantía y se declara.
Reglamento europeo de IA	**No aplica**	ColaboraFP no usa inteligencia artificial; así consta en el aviso legal.

2. Pasos administrativos pendientes

#	Paso	Dónde y cómo
1	**Publicar las nuevas reglas de Firestore**	Firebase → Firestore Database → Reglas → pegar `colaborafp/firebase/firestore.rules` → Publicar. Sin este paso la nueva versión no funcionará.
2	**Completar los datos del titular**	Netlify → Project configuration → Environment variables: `VITE_CENTRO_TITULAR`, `VITE_CENTRO_NIF`, `VITE_CENTRO_DIRECCION`, `VITE_CENTRO_EMAIL`, `VITE_CENTRO_DPD` y, si procede, `VITE_CENTRO_REGISTRO` y `VITE_CENTRO_TELEFONO`. Después: Deploys → Trigger deploy. Mientras falten, las páginas legales los muestran como «pendiente».
3	**Contrato de encargo con**	Revisar y aceptar las condiciones de tratamiento de datos de Firebase / Google Cloud (Data Processing and Security Terms) desde la configuración del proyecto o la sección de privacidad

	Google (art. 28 RGPD)	de la consola de Google Cloud, y archivar una copia. La ubicación exacta del botón puede variar según la versión de la consola.
4	**Contrato de encargo con Netlify**	El Data Processing Addendum de Netlify se incorpora a sus condiciones de servicio: descargarlo desde la sección legal de netlify.com y archivarlo con la cuenta del centro.
5	**Activar el borrado automático (TTL)**	Firestore → TTL (Time-to-live) → crear una política con el campo `expire_at` para cada grupo de colecciones: `rooms`, `pins`, `resources`, `chunks` y `reports`. Actúa como respaldo: el panel del profesor ya elimina lo caducado al entrar.
6	**Comprobar la ubicación de los datos**	Firestore → Ubicación de la base de datos: debe ser europea (p. ej. `eur3`). Si no lo es, la política de privacidad debe ajustarse.
7	**Borrar los datos de la versión anterior**	Firestore → Datos: eliminar las colecciones antiguas de nivel superior `resources` y `fileChunks`. Las nuevas reglas ya impiden acceder a ellas.
8	**Inscribir el tratamiento en el RAT**	Añadir la ficha del apartado 3 al Registro de Actividades de Tratamiento del centro (art. 30 RGPD) e informar al Delegado de Protección de Datos.
9	**Revisión periódica**	Revisar la declaración de accesibilidad y estas medidas al menos una vez al año o cuando cambie la aplicación.

3. Ficha para el Registro de Actividades de Tratamiento

Campo	Contenido
Nombre del tratamiento	ColaboraFP – recursos de clase en tiempo real
Responsable	[Razón social y NIF del titular del centro] — Centro de Formación Profesional José Ramón Otero
Delegado de Protección de Datos	[Contacto del DPD]
Finalidad	Compartir recursos didácticos entre el profesorado y su alumnado durante la actividad lectiva, moderar las aportaciones del alumnado y atender notificaciones de contenido.
Base jurídica	Art. 6.1.e RGPD (función educativa; D. A. 23.ª LOE). Profesorado: art. 6.1.b RGPD.
Interesados	Profesorado del centro; alumnado (puede incluir menores de edad).
Categorías de datos	Profesorado: nombre, correo institucional, credenciales (gestionadas por Firebase Authentication). Alumnado: alias opcional y contenidos aportados. Notificaciones: motivo y descripción, de forma anónima. Datos técnicos de conexión (IP) tratados por los proveedores. No se tratan categorías especiales.
Destinatarios / encargados	Google Ireland Ltd. (Firebase Authentication y Cloud Firestore, UE); Netlify, Inc. (alojamiento web, EE. UU.). Sin cesiones a terceros.
Transferencias internacionales	Netlify, Inc. (EE. UU.): Marco de Privacidad de Datos UE-EE. UU. y/o cláusulas contractuales tipo (arts. 45-46 RGPD).
Plazos de supresión	Salas cerradas automáticamente a las 12 h; sala y todo su contenido borrados a los 60 días de su creación; cuenta del profesorado mientras preste servicio o hasta que la elimine.
Medidas de seguridad	Las del apartado 5.

4. ¿Es necesaria una evaluación de impacto (EIPD)?

Según la lista de tratamientos de la AEPD que requieren EIPD, solo concurre un criterio: datos de personas vulnerables (alumnado que puede ser menor de edad). No hay datos de categorías especiales, ni

elaboración de perfiles o decisiones automatizadas, ni tratamiento a gran escala, ni observación sistemática, ni uso de tecnologías innovadoras. Además, el alumnado no se identifica (alias opcional) y los datos se borran a los 60 días. Con un solo criterio, **no se considera obligatoria una EIPD**. Se recomienda documentar esta conclusión con el DPD.

5. Medidas técnicas y organizativas implementadas

Medida	Detalle
Control de acceso del profesorado	Solo correos `@jrotero.es` verificados (comprobado en la aplicación y en las reglas del servidor). Contraseñas de 8 o más caracteres con letras y números.
Aislamiento entre salas	Recursos, archivos y notificaciones se guardan dentro de su sala; las reglas impiden consultas que abarquen varias salas.
PIN	6 caracteres alfanuméricos sin caracteres ambiguos, generados con `crypto.getRandomValues`; solo resolubles con la sala abierta; no listables.
Ventana de exposición	Cierre automático a las 12 h; el alumnado solo puede aportar con la sala abierta.
Minimización y conservación	Alumnado sin cuenta; alias opcional con aviso de no usar datos personales; borrado automático a los 60 días, que no se puede ampliar.
Moderación y notificación	Aprobación previa de las aportaciones; notificación de contenido con retirada en un clic; ejecutables bloqueados; archivos de 5 MB como máximo.
Integridad de los datos	Las reglas validan los campos, tamaños y tipos de cada documento; los archivos solo se escriben de forma atómica junto a su recurso.
Transporte y navegador	HTTPS con HSTS; CSP restrictiva (solo el propio dominio y Firebase); X-Frame-Options; Permissions-Policy sin cámara, micrófono ni ubicación.
Terceros	Sin cookies, analítica ni publicidad; tipografías servidas desde el propio dominio.

6. Verificaciones realizadas

Prueba	Resultado
Reglas de seguridad (emulador oficial de Firebase)	22 intentos de abuso bloqueados y 6 accesos legítimos permitidos. Bloqueados, entre otros: listar recursos de todas las salas, listar PIN, resolver el PIN de una sala cerrada, aportar a una sala cerrada, autoaprobarse, ampliar el plazo de borrado, abrir una sala más de 12 h, crear salas con una cuenta sin verificar o de Gmail, y acceder a salas o notificaciones de otro profesor del centro.
Flujo completo en navegador	19 comprobaciones superadas (registro con verificación, PIN, aceptación de condiciones, moderación, notificación, cierre, supresión de la cuenta), también con la versión de producción y la CSP activa (0 bloqueos).
Conservación	Una sala caducada se elimina con todo su contenido al entrar el profesor en su panel; la vigente se conserva.
Accesibilidad	axe-core 4.14 (WCAG 2.0 y 2.1, A y AA): 0 incumplimientos en 40 pantallas. Revisión manual con teclado: enlace de salto, foco atrapado y devuelto en los diálogos, movimiento reducido.

> **Nota:** este documento describe las medidas técnicas implantadas y los pasos pendientes. No sustituye el asesoramiento del Delegado de Protección de Datos ni de la asesoría jurídica del centro, que deben validar los textos legales antes de su publicación definitiva.